Checklist de segurança

Treino · Personal Perto · treino.personalperto.com.br · Gerado em 16/10/2026 · PRs #114, #115, #116, #119 e #120 (mergeadas)

1	3	6	8	431
crítica corrigida	altas corrigidas	médias corrigidas	baixas / médias-baixas	testes passando

Rodada 1 — Auditoria inicial (PR #114)

Severidade	Vulnerabilidade	Correção	Status
CRÍTICA	Qualquer personal logado podia marcar a si mesmo como admin (`professionals.is_admin` gravável), liberando as funções `admin_*` e a tomada de conta de qualquer personal.	Migration `20261039`: UPDATE por coluna + trigger que bloqueia `is_admin`.	✓ Confirmado: tentativa pela API retorna 42501

Verificado sem achados: `anon` sem acesso a nenhuma tabela; nenhum segredo no repositório; nenhum ponto de XSS (`dangerouslySetInnerHTML`); `npm audit` de produção com 0 vulnerabilidades.

Rodada 2 — Correções da auditoria (PR #115 e #116)

Severidade	Vulnerabilidade	Correção	Status
ALTA	`admin-actions` devolvia o link de recuperação de senha na resposta.	Usa `resetPasswordForEmail`; resposta só `{ success, email }`; painel sem o link.	✓ Merge · deploy: confirmar
MÉDIA	Sem Content-Security-Policy.	`<meta>` de CSP e `referrer` só no build.	✓ Merge
MÉDIA	Sem rate limit nas funções públicas.	Migration `20261040` + `_shared/rateLimit.ts` em `mp-webhook`, `send-whatsapp`, `treino-publico`, `confirmar-consentimento-saude`.	✓ Tabela tem dados reais de IP
BAIXA	`.gitignore` não cobria `.env.production`.	`.env.*` com exceção de `.env.example`.	✓
BAIXA	`console.*` ia para o build.	Removido no build (Rolldown).	✓
BAIXA	`admin-actions` expunha a mensagem de erro do Auth.	Mensagem fixa; detalhe só no log do servidor.	✓
BAIXA	Formatação do WhatsApp (`* _ ~` e crases) vinda dos nomes.	`nomeLimpo` nos nomes das mensagens.	✓
BAIXA	CORS aceitava `localhost` em produção.	Só com `ALLOW_LOCALHOST_CORS=true`.	✓
BAIXA	FKs sem checagem entre personais (`WITH CHECK`).	Migration `20261041` (5 policies).	⚠ Rodar/confirmar
DOC	`jwt_expiry` só no dashboard.	`[auth] jwt_expiry = 3600` no `config.toml` (documentação).	✓

Correção ao relatório: o pendente "`CRON_SECRET` em tempo constante" estava errado — `segredoCronValido` já compara em tempo constante.

Rodada 3 — Validação dos lotes 1 e 2 (21 itens, sem alterar nada)

- Nenhum segredo hardcoded; nenhum `.env` no histórico git (299 commits varridos).
- Nenhuma Edge Function lê `professional_id` do corpo da requisição.
- `anon` sem acesso; funções `SECURITY DEFINER` com `REVOKE`; sem SQL dinâmico; sem upload de arquivo; e-mails com `escaparHtml`.
- Pentest por leitura: `send-whatsapp` sem JWT → 401; `admin-actions` sem `is_admin` → 403; cron sem segredo → 401.

Rodada 4 — Revisão como invasor (PR #119 e #120)

Severidade	Vulnerabilidade	Correção	Status

ALTA	E-mail com a nossa marca sem limite por personal (relé de spam/phishing).	20/h e 60/dia por personal (falha fechada); exige e-mail confirmado; nomes sem links no corpo do e-mail.	**✓ Merge · deploy: confirmar**
ALTA	Separação entre personais dependia só da RLS (grant padrão em toda tabela).	Migration `20261044`: grants mínimos; sem grant automático para tabelas futuras.	**✓ Confirmado: teste de leitura (SQL) e de escrita (API)**
MÉDIA	IP forjável no rate limit.	Só `cf-connecting-ip` (confirmado nos dados do `rate_limit`).	✓
MÉDIA	Rate limit falhava aberto; tabela inflável.	`verificarLimite`: `mp-webhook` e envio de e-mail falham fechados; chave ≤ 120; cron de limpeza.	**✓ Merge · cron: confirmar**
MÉDIA	Link "sem prazo" era credencial eterna.	Teto de 30 dias.	**✓ Merge**
MÉDIA	CSP frouxa (`unsafe-inline`, curinga do Supabase, imagens de qualquer HTTPS).	`src/config/csp.ts`: sem `unsafe-inline`; host exato do Supabase; `img-src` restrito.	**✓ Testado local · produção: confirmar**
MÉDIA-BAIXA	`admin-actions` aceitava qualquer e-mail; log podia falhar em silêncio.	Valida e-mail; exige personal cadastrado; 10/h por admin; log antes da ação.	**✓ Merge · deploy: confirmar**
MÉDIA-BAIXA	Sem limite de tamanho nas colunas de texto livre.	Migration `20261045`: 42 `CHECK … NOT VALID`; Zod do aluno alinhado.	**✓ Confirmado (violadores vazios; migration rodada)**

Guardas que ficam no repositório (contra regressão)

- `supabase/migrations.test.ts` — toda tabela nova precisa de RLS e de GRANT/REVOKE explícito; `is_admin` nunca entra no UPDATE por coluna.
- `supabase/tests/isolamento.sql` — teste de isolamento entre personais (só leitura).
- `supabase/tests/limites_violadores.sql` — dados acima dos limites de tamanho.
- 431 testes automatizados passando.

Itens que dependem de confirmação

☐ Migrations `20261041` (WITH CHECK), `20261042` (modalidade_foco) e `20261043` (expira_em) rodadas? (`20261040` confirmada pelos IPs no `rate_limit`.)
☐ Cron `limpar-rate-limit` agendado.
☐ Deploy das Edge Functions: `admin-actions`, `enviar-consentimento-saude`, `mp-webhook`, `send-whatsapp`, `treino-publico`, `confirmar-consentimento-saude`, `gerar-link-treino`.
☐ Produção com o console aberto: login com Turnstile, autocomplete de local (Google Places) e envio de treino à distância (a CSP nova pode bloquear algum host).
☐ Dashboard do Supabase: limites do Auth, captcha ativo (login, cadastro e reset) e nenhum bucket de Storage criado à mão.
☐ Chave do Google Maps restrita por referrer a `treino.personalperto.com.br` e só à Places API.

Riscos aceitos

- Sessão em `localStorage` (mitigada pela CSP e pela ausência de XSS conhecido).
- `frame-ancestors` e `X-Content-Type-Options` não funcionam via `<meta>` no GitHub Pages (só com proxy, como a Cloudflare).
- Crons protegidos só por `CRON_SECRET`, sem rotação automática.
- Dependências de desenvolvimento com CVE (`sharp`, `source-map-js`): afetam só o build, não o bundle.

Pendências abertas

- MFA do admin (precisa antes de uma tela de cadastro do segundo fator).
- Limites de quantidade por conta (decisão de produto).
- `VALIDATE CONSTRAINT` dos 42 `CHECK` de tamanho (violadores vieram vazios).
- Etapa 2 dos grants: tirar DELETE/UPDATE não usados das tabelas com policy ALL.
- Evolution API (WhatsApp não oficial): considerar instância e número dedicados.

Fonte: `docs/SECURITY-AUDIT.md` e as PRs #114, #115, #116, #119 e #120 do repositório Treino-PP. Este documento não contém valores de segredos.